

1. Bug Bounty Hunting Process

1.1 Что такое Bug Bounty Program

Bug Bounty Program (BBP) — программа поощрения за обнаружение и сообщение об уязвимостях. Также называется Vulnerability Rewards Program (VRP).

BBP — это непрерывное и проактивное тестирование безопасности, которое дополняет внутренние аудиты кода и пентесты.

HackerOne: “Continuous testing, constant protection” Интегрируется в существующий жизненный цикл разработки.

1.2 Типы Bug Bounty программ

Тип	Описание
Private	Доступ только по приглашениям. Основаны на репутации хакера
Public	Доступны всему сообществу
Parent/Child	Общий пул наград и команда безопасности для компании и дочерних фирм

Важно: BBP и VDP — не одно и то же!

- VDP (Vulnerability Disclosure Program) — только руководство по сообщению об уязвимостях
- BBP — материальное вознаграждение за найденные баги

1.3 Code of Conduct (Кодекс поведения)

Устанавливает ожидания по поведению участников. Нарушения учитываются при приглашениях в приватные программы.

Ключевой принцип: Баланс между профессионализмом и техническими навыками.

1.4 Структура Bug Bounty программы

Элемент	Описание
Vendor Response SLAs	Когда и как вендор отвечает
Access	Создание/получение аккаунтов
Eligibility Criteria	Критерии участия
Responsible Disclosure Policy	Сроки и координация раскрытия
Rules of Engagement	Правила взаимодействия
Scope	In-scope: домены, IP, типы уязвимостей
Out of Scope	Исключения
Reporting Format	Формат отчетов
Rewards	Награды
Safe Harbor	Защита исследователей
Legal Terms	Юридические условия

1.5 Где искать Bug Bounty программы

HackerOne Directory — один из лучших ресурсов для поиска ВБР. Позволяет найти организации с программами и контакты для сообщения об уязвимостях.

1.6 Структура баг-репорта

1.6.1 Основные элементы

Элемент	Описание
Vulnerability Title	Тип уязвимости, затронутый домен/параметр/эндпоинт, влияние
CWE & CVSS Score	Характеристика и серьезность
Vulnerability Description	Причина возникновения
Proof of Concept (POC)	Пошаговое воспроизведение
Impact	Что может сделать атакующий, бизнес-влияние
Remediation	Исправление (опционально)

Ключевые принципы:

- Краткость и ясность
- Пошаговое воспроизведение
- Профессионализм в коммуникации

1.6.2 Взаимодействие с командой безопасности

Правила:

1. Не спамить
2. Дать время на обработку (смотреть SLA)
3. Использовать только официальные каналы
4. Быть профессионалом
5. В спорах — объяснять свою позицию по CVSS
6. Если не помогают аргументы — обращаться к медиации

1.7 CVSS v3.1 (Common Vulnerability Scoring System)

1.7.1 Attack Vector (Вектор атаки)

Значение	Описание
Network (N)	Уязвимость эксплуатируется удаленно через сеть
Adjacent (A)	Атакующий в той же физической/логической сети
Local (L)	Требуется локальный доступ к системе
Physical (P)	Требуется физическое взаимодействие

1.7.2 Attack Complexity (Сложность атаки)

Значение	Описание
----------	----------

Low (L)	Не требует специальной подготовки
High (H)	Требует специальной подготовки и разведки

1.7.3 Privileges Required (Требуемые привилегии)

Значение	Описание
----------	----------

None (N)	Не требуются привилегии
Low (L)	Требуются стандартные пользовательские права
High (H)	Требуются права администратора

1.7.4 User Interaction (Взаимодействие с пользователем)

Значение	Описание
----------	----------

None (N)	Атака выполняется без участия пользователя
Required (R)	Требуется действие пользователя

1.7.5 Scope (Область влияния)

Значение	Описание
----------	----------

Unchanged (U)	Влияние ограничено уязвимым компонентом
Changed (C)	Влияние выходит за пределы уязвимого компонента

1.7.6 Confidentiality, Integrity, Availability (CIA)

Параметр	Описание
----------	----------

Confidentiality	Конфиденциальность: None/Low/High
Integrity	Целостность: None/Low/High
Availability	Доступность: None/Low/High

—

1.8 Примеры отчетов

1.8.1 Пример 1: Stored XSS

Title: Stored Cross-Site Scripting (XSS) in X Admin Panel **CWE:** CWE-79 (Cross-site Scripting) **CVSS:** 5.5 (Medium)

Описание: Уязвимость в механизме загрузки файлов. Имя файла отражается в браузере и сохраняется в БД без санитизации.

РОС:

1. Загрузить файл с именем: "><svg onload = alert(document.cookie)>.docx
2. Другой администратор открывает файл → выполняется JS-код

Impact: Кража сессий, hijacking, дефейс, редирект на вредоносные сайты.

1.8.2 Пример 2: CSRF

Title: Cross-Site Request Forgery (CSRF) in Consumer Registration **CWE:** CWE-352 (CSRF) **CVSS:** 5.4 (Medium)

Описание: Отсутствие anti-CSRF токенов в форме регистрации.

РОС:

1. Перехватить запрос на регистрацию
2. Создать HTML страницу с CSRF формой
3. Отправить ссылку жертве с активной сессией

Impact: Создание финтех-приложения и API-ключа от имени жертвы.

1.8.3 Пример 3: RCE

Title: IBM WebSphere Java Object Deserialization RCE **CWE:** CWE-502 (Deserialization of Untrusted Data) **CVSS:** 9.8 (Critical)

Описание: Уязвимость в десериализации Java-объектов в Apache Commons Collections.

РОС:

1. Идентифицировать base64-кодированные сериализованные объекты (r00)
2. Создать SOAP запрос с вредоносным объектом
3. Исполнить команду на сервере

Impact: Полный контроль над системой (RCE).

1.9 Итоговый чек-лист баг-хантера

1. Изучить Code of Conduct
2. Внимательно прочитать Policy
3. Проверить Scope (in/out)
4. Соблюдать Rules of Engagement
5. Профессионально оформить отчет
6. Приложить РОС с шагами
7. Указать CWE и CVSS
8. Описать Impact (бизнес-влияние)
9. Не спамить в поддержку
10. Общаться только через официальные каналы

Запомните: Время — важнейший ресурс в баг-хантинге. Четкий отчет сокращает время на воспроизведение и триаж.